ÖRNEK MİMARİSİ

Günün üç makinesi

Şişeleme Hattı

SİZİN MAKİNENİZ

Föylerdeki tüm görevleri bu makine üzerinde yapacaksınız: envanter, senaryo, tasarım. Gün boyu sizinle gelişecek.

PaketPro 3000

İŞLENMİŞ ÖRNEK

Paketleme makinesi. Her lab'da "çözülmüş hâli" onun üzerinden göstereceğiz — "3 varlığımız var" diyen ekibin 16 kapılı makinesi.

Karabudak Kbotic

GERÇEK PİLOT · YZ

Yapay zekâlı robotik boya hattı — bu programın gerçek pilot vakası. Günün sonunda YZ güvenliğini onun üzerinde tartışacağız.

Üç makine, tek yöntem: aynı sorular her makinede işler. Sizin makineniz dördüncü olacak.

Neden şimdi? İki tarih

11 Eylül 2026

CRA — Siber Dayanıklılık Yasası

- Bildirim yükümlülüğü başlar
- 24 saat / 72 saat / 14 gün zinciri
- Ceza tavanı: 15 M€ veya cironun %2,5'i

20 Ocak 2027

Makine Tüzüğü (AB) 2023/1230

- Geçiş dönemi YOK
- Siber güvenlik CE'nin ön şartı
- Mekanik yeterli değil

İki mevzuat birbirini otomatik karşılamaz — her biri için AYRI kanıt üretilir. Kanıt üretmek aylar alır; kanıtsız denetime girilmez. Bugün başlamanın sebebi bu.

KAVRAM ÇIPASI

Bir güvenlik açığı emniyeti bozarsa



- Uzak erişim / açık kapı
- Makinenin beyni (PLC / IPC)
- Emniyet parametresi değişir
- Emniyet fonksiyonu bozulur
- **Fiziksel sonuç — insana zarar**

Altın kural: zincir "veri çalındı" ile değil, FİZİKSEL bir sonuçla biter. Yoksa emniyet bulgusu değildir.

LABORATUVAR 1

Makinenin Safety Architecture'ını Çöz

Üreteceğiniz çıktı: **Safety Function Map**

LAB 1 · KAVRAM

Önce iki kelime: emniyet ve güvenlik

EMNİYET (safety)

Kaza sonucu, kimsenin istemeden oluşabilecek fiziksel zararı önler.

- Işık perdesi elinizi presten korur
- Acil durdurma hattı durdurur
- Amaç: beklenmeyen fiziksel olay

GÜVENLİK (security)

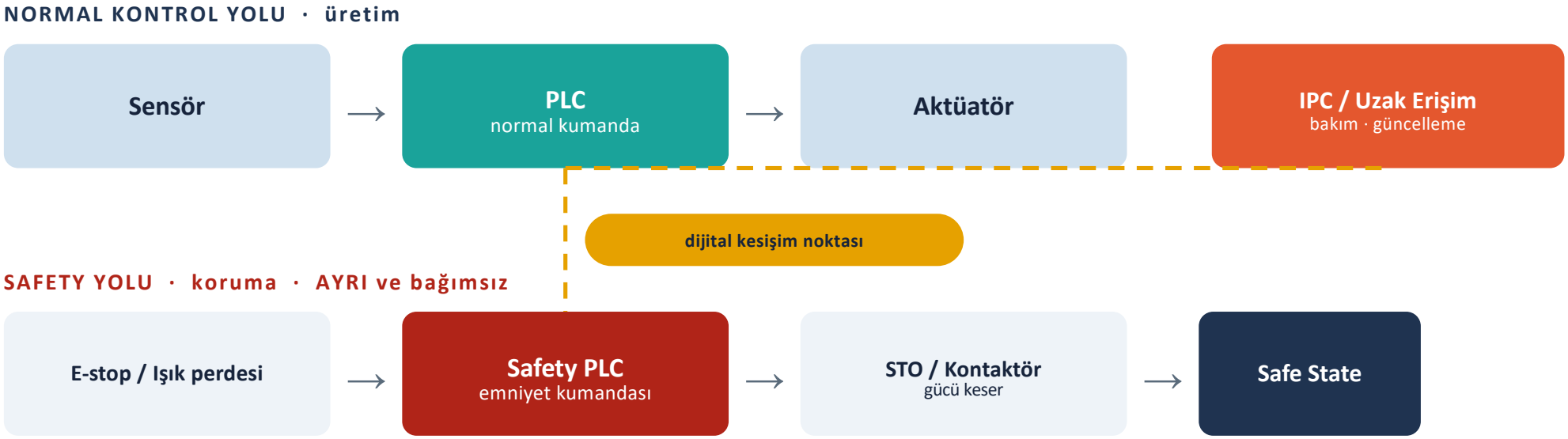
Kötü niyetli, kasıtlı girişimlere karşı korur.

- Erişim kontrolü, kimlik doğrulama
- Ağ segmentasyonu
- Güncel yazılım, izleme

Bootcamp'in tamamı bu ikisinin kesiştiği noktada kurulur.

LAB 1 · GÖRSEL

Bir makinenin iki kontrol yolu



Üst yol üretim içindir; alt yol hayat için. Ama IPC alt yola dijital dokunabilirse, siber müdahale emniyet fonksiyonunu bozabilir.

LAB 1 · KAVRAM

Bir koruma ne kadar güvenilir olmalı?

Her emniyet fonksiyonunun bir gerekli performansı vardır — PLr (Performance Level required) veya SIL (Safety Integrity Level). Mantık basit:

Şiddet

Yaralanma ne kadar ağır olur?

Maruz kalma

İnsan tehlikeye ne sıklıkta yaklaşır?

Kaçınabilirlik

Tehlikeden kaçmak mümkün mü?

Risk ne kadar büyükse (şiddet × sıklık × kaçınılamazlık), gereken performans o kadar yüksek: PL a → e / SIL 1 → 3.

Koruma keyfî değil; riskle orantılı. Ve bu performans safety PLC konfigürasyonuna bağlı — konfigürasyon değişirse performans da değişir.

Not: Bugün ISO 13849 hesabı yapmıyoruz; amacımız bu mantığı görmek — koruma riskle orantılıdır ve dijitaldir.

LAB 1 · GÖREV · Şişeleme Hattı

Göreviniz — föyünüze cevaplayın

1. Tehlike nedir? İnsan neyden zarar görür?
2. Safety function hangisidir?
3. Safety-related control system nerede?
4. Normal PLC ile Safety PLC farkı?
5. PLr / SIL neden var?
6. Safe state nedir?
7. Hangi dijital bağımlılıklar var?
8. Siber müdahale nereden bozar?

Grup çalışması · 20 dk · her soru bir sonrakini açar; sırayla ilerleyin.

LABORATUVAR 2

IEC 62443 Mini Workshop

Üreteceğiniz çıktı: **Zone / Conduit Diagram**

LAB 2 · KAVRAM

İki kavram: zone ve conduit

ZONE (bölge)

Benzer güvenlik seviyesindeki cihazların gruplandığı alan.

- Aynı kritiklik = aynı bölge
- Safety PLC en yüksek bölgede
- Bölge içi güvenilir kabul edilir

CONDUIT (geçiş)

İki bölge arasındaki kontrollü bağlantı.

- Her geçiş bir kontrol noktası
- Kim, ne, hangi yönde geçer?
- En riskli conduit = uzak erişim

62443'ün maddesini ezberlemeyeceğiz — 62443 gibi DÜŞÜNMEYİ öğreneceğiz: bölge topla, geçişi kontrol et.

LAB 2 · KAVRAM

Saldırı yüzeyi — altı kategori

"Görmediğin kapıyı kilitleyemezsin." Korumanın ilk adımı sayımdır — ve sayım hafızayla değil, kategoriyle yapılır:

1 Donanım

PLC, HMI, sürücü, anahtar, robot

2 Yazılım / firmware

her cihazın sürümü

3 Hesaplar

operatör, bakım, tedarikçi

4 Sertifika / anahtar

VPN, entegrasyon anahtarları

5 Dış bağlantı

VPN, bulut, 4G, MES

6 Kritik veri akışı

hangi veri nereye gidiyor

Föyünüzdeki envanter görevi bu altı kategoriyle ilerleyecek — her kategoride üç kez "başka?" diye sorun.

İŞLENMİŞ ÖRNEK · PaketPro 3000

"3 varlığımız var" — gerçekten öyle mi?

Ekibin sandığı

3

PLC · HMI · motor sürücüsü

→

Sistematik envanter sonrası

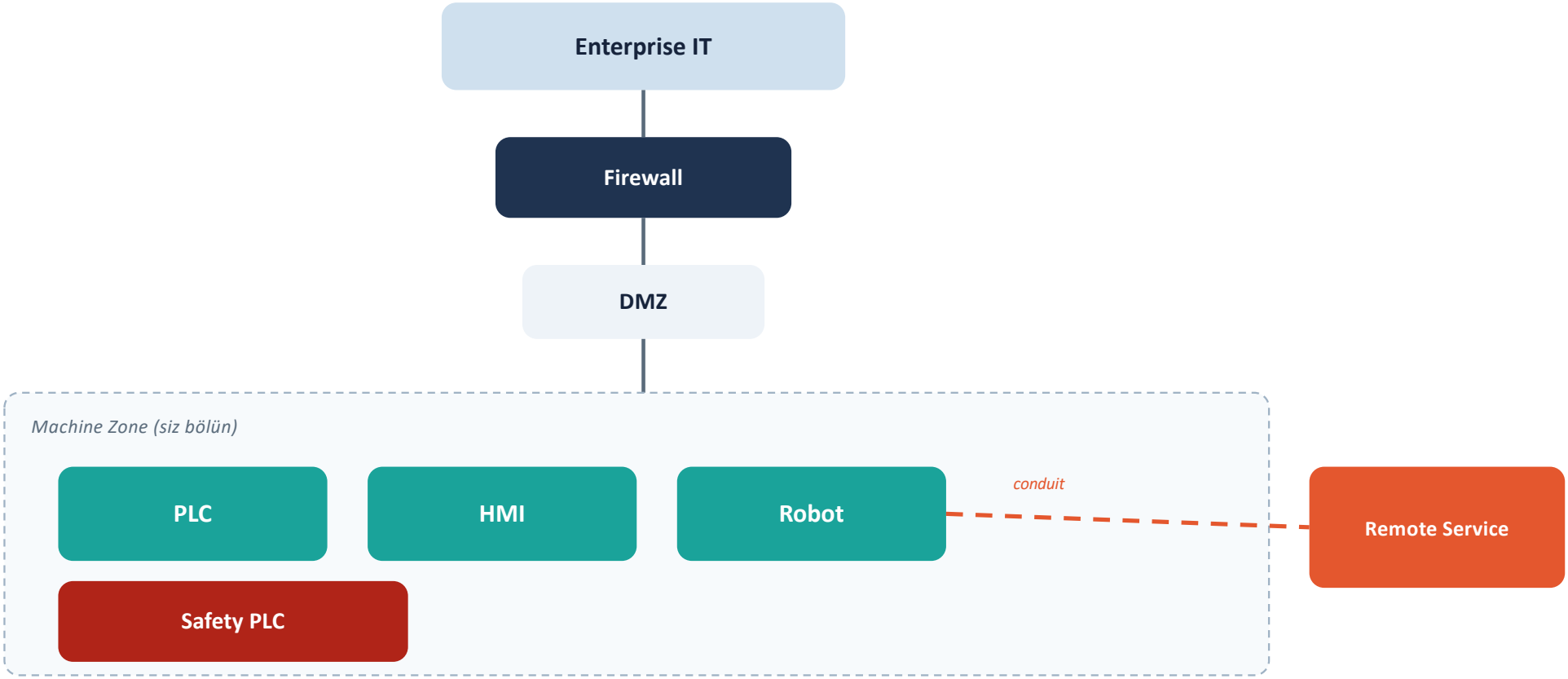
16 varlık + 5 dış bağlantı

- emniyet PLC'si · web arayüzü açık HMI (port 80)
- internete açık uzak bakım modülü
- "admin/admin" hesabı · kartonda yazılı Wi-Fi parolası
- dışarı akan bulut telemetrisi · 2 kilitsiz USB

Bir saldırgan, sizin bildiğiniz kapıdan girmez — bilmediğiniz kapıdan girer.

LAB 2 · GÖREV · Şişeleme Hattı

Fabrika/makine ağı — bölgelere ayırın



Görev: önce föyle envanter (25 dk), sonra bu ağı bölgelere ayırın (20 dk). Kilit soru: Safety PLC ayrı zone mu?

LAB 2 · GÖREV

Karar: tedarikçi uzaktan PLC'ye erişmek istiyor

Aracı?

Doğrudan / Jump server

Tünel?

Açık / VPN

Kimlik?

Parola / MFA

Hesap?

Paylaşılan / Kişisel

Kayıt?

Yok / Tam oturum kaydı

Zamanlama?

Sürekli açık / Varsayılan kapalı

Her satırda seçiminizi VE nedenini yazın. "Bu altı kararı verirken 62443'ün mantığını uçtan uca uyguladınız."

LABORATUVAR 3

Threat & Risk Lab + Safety 4.0 Risk Matrix

Üreteceğiniz çıktı: **Risk Register**

LAB 3 · KAVRAM

Bir tehdit senaryosu beş parçadan oluşur

Profil	kim? (dört saldırgan tipinden — sonraki slayt)
Giriş	hangi kapı? (envanterdeki dış bağlantı)
Eylem	ne yapar?
Zincir	nasıl ilerler?
Sonuç	FİZİKSEL etki (yaralanma/yangın)

Kural: senaryo FİZİKSEL bir sonuçla biter. "Veri çalındı" ile biterse bir adım daha gidin.

LAB 3 · KAVRAM

Dört saldırgan profili

"Kim?" sorusuna dört cevap — her profil farklı bir kapıyı ve farklı bir zinciri sever:



Meraklı içeriden

Yetkisini aşan çalışan

paylaşılan hesap · USB · reçete merakı



Fırsatçı dış

İnternette açık kapı tarayan otomatik saldırı

açık uzak bakım · 4G modem · port 80



Hedefli

Sizi özellikle seçen, kaynaklı saldırgan

oltalama + zincirleme · sabırlı keşif



Tedarik zinciri

Tedarikçi / güncelleme üzerinden

imzasız firmware · servis dizüstüsü

Senaryonuzu bu dört profilden biriyle açın — profil, kapıyı ve zinciri belirler.

LAB 3 · KAVRAM

Hangisini önce? Safety 4.0 Risk Matrix

L

Olasılık / İstismar edilebilirlik

Bu kapı ne kadar kolay istismar edilir?

S

Safety Impact

Fiziksel sonuç ne kadar ağır?

E

Exposure

Bu yol dışa ne kadar açık?

Skor = L × S × E (her biri 1–3, sonuç 1–27)

Kritik 18–27	Yüksek 9–17	Orta 4–8	Düşük 1–3

Kural: S = 3 ise skor düşük olsa bile öne alınır — insana zarar her zaman görünür kalır.

LABORATUVAR 4

Secure Remote Access Challenge

Üreteceğiniz çıktı: **Secure Architecture**

LAB 4 · GÖRSEL

Mevcut → Hedef: uzak erişimi yeniden tasarla

MEVCUT (savunmasız)

Makine → doğrudan internet → paylaşılan hesap, kayıt yok

HEDEF (güvenli)

Makine → jump server → VPN → MFA → kişisel hesap → kayıt

1. Ara nokta (doğrudan açık değil)
2. Kişisel hesap (ortak yok)
3. İkinci faktör (MFA)
4. Varsayılan kapalı, süre sınırlı
5. Oturum kaydı (kim/ne zaman)

Functional safety köprüsü

Saldırgan yine de girerse? Emniyet fonksiyonunu IPC'den BAĞIMSIZ bir safety PLC'ye alın — IPC ele geçse bile makine güvenli tarafta kalır. En güçlü tek yatırım.

LABORATUVAR 5

SBOM / CVE / Patch Lab

Üreteceğiniz çıktı: **Vulnerability Decision**

LAB 5 · KAVRAM

Üç terim: SBOM, CVE, CVSS



SBOM

Yazılım bileşen listesi

Makinenizdeki yazılımların 'malzeme listesi'



CVE

Bilinen açığın kayıt no'su

Her açığın benzersiz kimliği (CVE-YYYY-NNNN)



CVSS

Açığın ciddiyet puanı

0–10 arası: ne kadar tehlikeli?

Bir CVE sizi etkiler mi? Üç şart: bileşen sizde VAR, o SÜRÜM etkileniyor, açık ULAŞILABİLİR. SBOM olmadan bilemezsiniz.

LABORATUVAR 6

CRA Incident Simulation

Üreteceğiniz çıktı: **Incident Workflow**

LABORATUVAR 7

AI Safety Challenge

Üreteceğiniz çıktı: **AI Fail-Safe Decision**

GERÇEK MAKİNE · YZ'Lİ BOYA HATTI

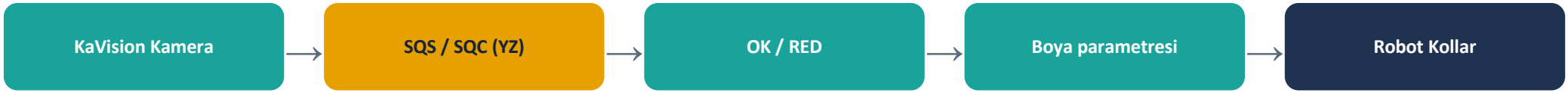
Pilot vaka: Karabudak Kbotic



Boya kabini: çözücü buharı → egzoz fanı (18.000 m³/s) birikimi önler. Egzoz durursa buhar birikir — tutuşma riski.

Kilit soru: Egzoz fanını IPC kumanda ediyorsa — ve IPC'ye uzaktan erişilebiliyorsa — bir siber müdahale bu emniyet fonksiyonunu durdurabilir mi? LAB 1'deki sarı çizgi, işte bu gerçek makinede.

Prediction ≠ Safety



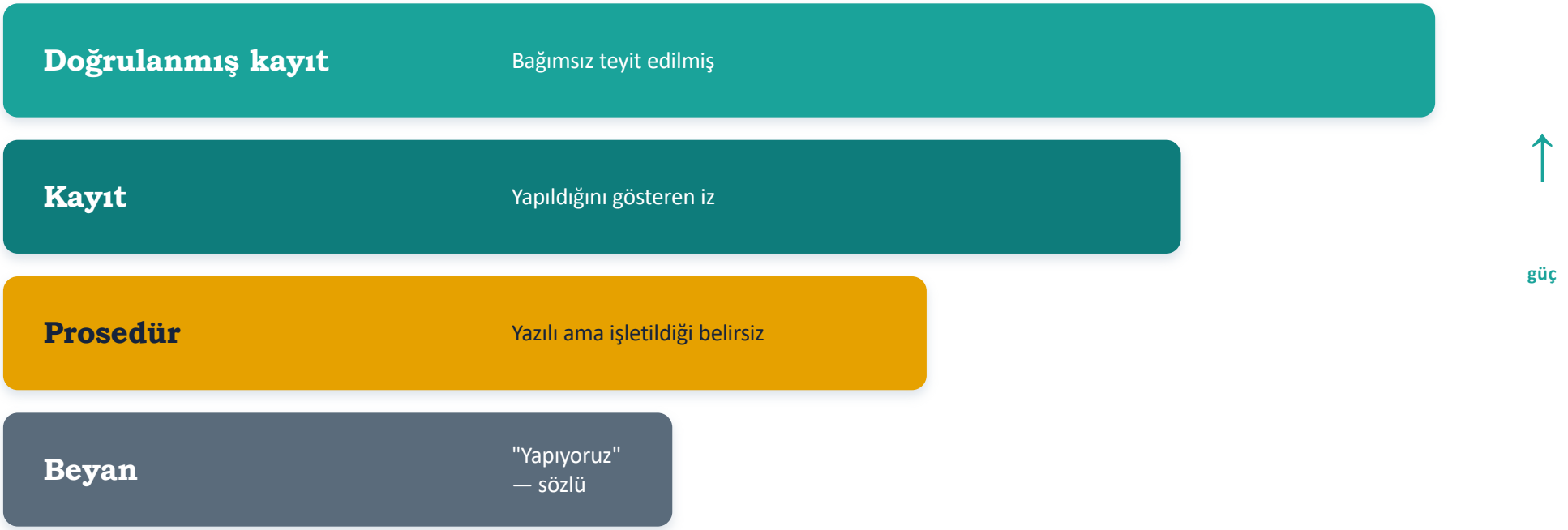
1 · SQC yanlış sınıflandırdı	Kusurluya OK — veya aşırı boya parametresi: daha çok çözücü buharı. İkinci kontrol / insan onayı
2 · Kamera girdisi bozuldu	Lens kirliliği / manipülasyon. Girdi bütünlüğü; şüpheli görüntüde reddet, güvenli varsayıma geç
3 · SQC confidence düştü	Model kararsız. Eşik tanımla; altında DUR, insana sor, güvenli parametreye dön

fail-safe · human override · monitoring · confidence threshold · fallback — güvenlik mimarisi YZ'nin DIŞINDA tanımlanır.

YÖNETİŞİM

Denetçi mantığı: kanıt hiyerarşisi

Denetçi "yaptık" demenizle yetinmez — kanıtın olgunluğuna bakar:



Evidence Pack'teki dört durum tam bu merdivendir: Yok → Taslak → Var → Doğrulanmış. Hedef: her başlıkta bir basamak yukarı.

YÖNETİŞİM

Evidence Pack — 15 başlık

"Yarın denetçi geldi — masaya hangi dosyaları koyacaksınız?"

01 Asset Inventory	02 Network Architecture	03 Safety Functions
04 Cyber Risk Assessment	05 Zone & Conduit	06 Remote Access Procedure
07 User/Role Matrix	08 Software/Firmware Inv.	09 SBOM
10 Vulnerability Records	11 Patch/Update Records	12 Backup & Restore
13 Incident Response	14 Change Management	15 Verification/Test

Her lab çıktısı bir başlığa oturur · durum: Yok / Taslak / Var / Doğrulanmış

YÖNETİŞİM

Safety 4.0 RACI — 'kim?' sorusu

İş	Tasarım	OT	IT	Safety	Servis	Yönetim
Asset inventory	R	R	C	C	C	**A**
Remote access	C	R	R	C	C	**A**
Patch / update	C	R	C	C	C	**A**
Safety change	C	C	C	R	C	**A**
Incident	C	R	R	C	C	**A**
Risk assessment	R	R	C	R	C	**A**

R = yapan · A = nihai sorumlu (tek) · C = görüşü alınan · I = bilgilendirilen. A'sı boş satır = sahipsiz iş → 90 günlük plana girer.

Yasal çerçeve

Referanslar: ISO 12100/13849, IEC 62061/61508, IEC 62443, ISO/IEC 42001, Makine Tüzüğü (AB) 2023/1230, CRA.

INSPECCO (NANDO 2459) × Kriptarium · Safety 4.0 Readiness Bootcamp